

Abstract

MITRE ATT&CK is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community. ATT&CK provides a common taxonomy for both offense and defense, and has become a useful conceptual tool across many cyber security disciplines to convey threat intelligence, perform testing through red teaming or adversary emulation, and improve network and system defenses against intrusions. The process MITRE used to create ATT&CK, and the philosophy that has developed for curating new content, are critical aspects of the work and are useful for other efforts that strive to create similar adversary models and information repositories.

1 Introduction

MITRE ATT&CK is a curated knowledge base and model for cyber adversary behavior, reflecting the various phases of an adversary's attack lifecycle and the platforms they are known to target. ATT&CK focuses on how external adversaries compromise and operate within computer information networks. It originated out of a project to document and categorize post-compromise adversary tactics, techniques and procedures (TTPs) against Microsoft Windows systems to improve detection of malicious behavior. It has since grown to include Linux and macOS, and has expanded to cover behavior leading up to the compromise of an environment, as well as technology-focused domains like mobile devices, cloud-based systems, and industrial control systems. At a high-level, ATT&CK is a behavioral model that consists of the following core components:

- Tactics, denoting short-term, tactical adversary goals during an attack;
- Techniques, describing the means by which adversaries achieve tactical goals;
- Sub-techniques, describing more specific means by which adversaries achieve tactical goals at a lower level than techniques; and
- Documented adversary usage of techniques, their procedures, and other metadata.

ATT&CK is not an exhaustive enumeration of attack vectors against software. Other MITRE efforts such as CAPEC™ [2] and CWET™ [3] are more applicable to this use case.

1.1 Background and History

ATT&CK was created out of a need to systematically categorize adversary behavior as part of conducting structured adversary emulation exercises within MITRE's FMX research environment. Established in 2010, FMX provided a "living lab" capability that allowed researchers access to a production enclave of the MITRE corporate network to deploy tools, test, and refine ideas on how to better detect threats. MITRE began researching data sources and analytic processes within FMX for detecting advanced persistent threats (APTs) more quickly under an "assume breach" mentality. Cyber game exercises were conducted on a periodic basis to emulate adversaries within the heavily monitored environment and threat hunting was performed to test analytic hypotheses against the data collected. The goal was to improve post-compromise detection of threats penetrating enterprise networks through telemetry sensing and behavioral analytics [4]. The primary metric for success was "How well are we doing at detecting documented adversary behavior?" To effectively work towards that goal, it proved useful to categorize observed behavior across relevant real-world adversary groups and use that information to conduct controlled exercises emulating those adversaries within the FMX environment. ATT&CK was used by both the adversary emulation team (for scenario development) and the defender team (for analytic progress measurement), which made it a driving force within the FMX research.

The first ATT&CK model was created in September 2013 and was primarily focused on the Windows enterprise environment. It was further refined through internal research and development and subsequently publicly released in May 2015 with 96 techniques organized

under 9 tactics. Since then, ATT&CK has experienced tremendous growth based on contributions from the cybersecurity community. MITRE has created several additional ATT&CK-based models were created based on the methodology used to create the first ATT&CK. The original ATT&CK was expanded in 2017 beyond Windows to include Mac and Linux and has been referred to as ATT&CK for Enterprise. A complementary model called PRE-ATT&CK was published in 2017 to focus on “left of exploit” behavior. ATT&CK for Mobile was also published in 2017 to focus on behavior in the mobile-specific domain. ATT&CK for Cloud was published in 2019 as part of Enterprise to describe behavior against cloud environments and services. ATT&CK for ICS was published in 2020 to document behavior against industrial controls systems.

2 ATT&CK Use Cases

Adversary Emulation – The process of assessing the security of a technology domain by applying cyber threat intelligence about specific adversaries and how they operate to emulate that threat. Adversary emulation focuses on the ability of an organization to verify detection and/or mitigation of the adversarial activity at all applicable points in their lifecycle.

ATT&CK can be used as a tool to create adversary emulation scenarios [5] to test and verify defenses against common adversary techniques. Profiles for specific adversary groups can be constructed out of the information documented in ATT&CK (see Cyber Threat Intelligence use case). These profiles can also be used by defenders and hunting teams to align and improve defensive measures.

Red Teaming – Applying an adversarial mindset without use of known threat intelligence for the purpose of conducting an exercise. Red teaming focuses on accomplishing the end objective of an operation without being detected to show mission or operational impact of a successful breach.

ATT&CK can be used as a tool to create red team plans and organize operations to avoid certain defensive measures that may be in place within a network. It can also be used as a research roadmap to develop new ways of performing actions that may not be detected by common defenses.

Behavioral Analytics Development – By going beyond traditional indicators of compromise (IoCs) or signatures of malicious activity, behavioral detection analytics can be used to identify potentially malicious activity within a system or network that may not rely on prior knowledge of adversary tools and indicators. It is a way of leveraging how an adversary interacts with a specific platform to identify and link together suspicious activity that is agnostic or independent of specific tools that may be used.

ATT&CK can be used as a tool to construct and test behavioral analytics to detect adversarial behavior within an environment. The Cyber Analytics Repository¹ (CAR) is one example of analytic development that could be used as a starting point for an organization to develop behavioral analytics based on ATT&CK.

Defensive Gap Assessment – A defensive gap assessment allows an organization to determine what parts of its enterprise lack defenses and/or visibility. These gaps represent blind spots for potential vectors that allow an adversary to gain access to its networks undetected or unmitigated.

ATT&CK can be used as a common behavior-focused adversary model to assess tools, monitoring, and mitigations of existing defenses within an organization's enterprise. The identified gaps are useful as a way to prioritize investments for improvement of a security program. Similar security products can also be compared against a common adversary behavior model to determine coverage prior to purchasing.

SOC Maturity Assessment – An organization's Security Operations Center is a critical component of many medium to large enterprise networks that continuously monitor for active

¹ <https://car.mitre.org>

threats against the network. Understanding the maturity of a SOC is important to determine its effectiveness.

ATT&CK can be used as one measurement to determine how effective a SOC is at detecting, analyzing, and responding to intrusions. Similar to the defensive gap assessment, a SOC Maturity assessment focuses on the processes a SOC uses to detect, understand, and respond to changing threats to their network over time.

Cyber Threat Intelligence Enrichment – Cyber threat intelligence covers knowledge of cyber threats and threat actor groups that impact cybersecurity. It includes information about malware, tools, TTPs, tradecraft, behavior, and other indicators that are associated to threats.

ATT&CK is useful for understanding and documenting adversary group profiles from a behavioral perspective that is agnostic of the tools the group may use. Analysts and defenders can better understand common behaviors across many groups and more effectively map defenses to them and ask questions such as “what is my defensive posture against adversary group APT3?” Understanding how multiple groups use the same technique behavior allows analysts to focus on impactful defenses that span many types of threats. The structured format of ATT&CK can add value to threat reporting by categorizing behavior beyond standard indicators.

Multiple groups within ATT&CK use the same techniques. For this reason, it is not recommended to attribute activity solely based on the ATT&CK techniques used. Attribution to a group is a complex process involving all parts of the Diamond Model [5], not solely on an adversary’s use of TTPs.

2.1 ATT&CK Coverage

ATT&CK use cases for defense and red teaming incorporate a concept of ATT&CK coverage. Whether you’re a defender looking at how many ATT&CK techniques can be detected in an enterprise, a red teamer tasked with testing ATT&CK behaviors, or a manager looking to acquire a new tool that aligns to ATT&CK, it’s important to note that in general, coverage of every ATT&CK technique is unrealistic. [7]

At its core, ATT&CK documents known adversary behavior and is not intended to provide a checklist of things that need to **all** be addressed. Not all adversary behaviors can or should be used as a basis for alerting or providing data to an analyst. An action as simple as running *ipconfig.exe* to troubleshoot a network connection may happen frequently within an environment. This procedure falls under System Network Configuration Discovery in ATT&CK and is in the knowledge base because adversaries have been known to use it to learn about the system and network they’re in. With this example, the ability to collect telemetry on instances of *ipconfig.exe* running in an environment may be enough “coverage” as a historical activity record that can be referenced later. If *ipconfig.exe* is frequently and legitimately used then notifying an analyst with an alert on each instance as potential intrusion behavior would be excessive. Another example is how to address use of Valid Accounts, whether they’re Local, Domain, or Cloud Accounts. Use of these accounts would normally occur in any environment, but the context of how the accounts are used may or may not indicate the use is malicious in nature. Again, it’s important that data related to account use be collected, but it would be rare for simple use of the accounts to indicate an alert condition to an analyst without further context.

The techniques within ATT&CK may have many procedures for how an adversary could implement them — and because adversaries are always changing, it is difficult to know what all those procedures are in advance. That makes discussing coverage of a technique tough, especially when some ways of detecting behavior rely on individual procedures and some may span multiple procedures or even an entire technique. Going back to the prior ipconfig.exe example, collecting data on ipconfig.exe running may be insufficient though for coverage of the System Network Configuration Discovery technique because the same details can be discovered by an adversary through other means, such as the Get-NetIPConfiguration cmdlet within PowerShell.

It is important to always review the threat intelligence on what techniques, sub-techniques, and procedures adversaries have used to understand the details and how variations might affect how you determine coverage. Anyone mapping to ATT&CK should be able to explain the procedures they cover. Similarly to how it's unrealistic to expect coverage of 100% of ATT&CK techniques, it's unrealistic to expect coverage of all procedures of a given technique, especially since we often cannot know all of them in advance.

Operationalizing ATT&CK for an organization also encompasses determining what it means for you to have “ATT&CK coverage”. Is it that you're collecting data relevant to all techniques or just the ones that are the most important and you expect to see? Do you expect to issue alerts on all techniques or just the rarest ones? Is it important that all relevant instances of a technique being seen get tagged with an ATT&CK mapping even if it may not have been performed due to a real incident? Is one, two, three, or more analytics addressing a technique sufficient to have confidence that a technique is covered? Does the definition of coverage expand beyond visibility to also cover controls and preventative measures to stop techniques from being used? Does your definition of coverage include conducting red team or adversary emulation tests to verify defenses or test for coverage gaps?

ATT&CK is just as much about the mindset and process of using it as much as it is the knowledge base itself. It serves as a grounded, threat-informed baseline of activity that everyone should know about. The process of gathering intelligence, implementing defenses based on that intelligence, checking if those defenses work, and improving defenses to better cover threats over time is what should be strived for, not 100% coverage of ATT&CK. When it comes to information security, the threats we face, new technologies, and the adaptability of goal-based adversaries, we cannot consider filling out a checklist as “done”.

3 The ATT&CK Model

The basis of ATT&CK is the set of techniques and sub-techniques that represent actions that adversaries can perform to accomplish objectives. Those objectives are represented by the tactic categories the techniques and sub-techniques fall under. This relatively simple representation strikes a useful balance between sufficient technical detail at the technique level and the context around why actions occur at the tactic level.

3.1 The ATT&CK Matrix

The relationship between tactics, techniques, and sub-techniques can be visualized in the ATT&CK Matrix. For example, under the Persistence tactic (this is the adversary's goal – to persist in the target environment), there are a series of techniques including Hijack Execution Flow, Pre-OS Boot, and Scheduled Task/Job. Each of these is a single technique that adversaries may use to achieve the goal of persistence. Figure 1 depicts the ATT&CK Matrix for Enterprise

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
9 techniques	10 techniques	18 techniques	12 techniques	34 techniques	14 techniques	23 techniques	9 techniques	16 techniques	16 techniques	9 techniques	13 techniques
Drive-by Compromise	Command and Scripting Interpreter (x)	Account Manipulation (x)	Abuse Elevation Control Mechanism (x)	Abuse Elevation Control Mechanism (x)	Brute Force (x)	Account Discovery (x)	Exploitation of Remote Services	Archive Collected Data (x)	Application Layer Protocol (x)	Automated Exfiltration	Account Access Removal
Exploit Public-Facing Application	Exploitation for Client Execution	BITS Jobs	Access Token Manipulation (x)	Access Token Manipulation (x)	Credentials from Password Stores (x)	Application Window Discovery	Internal Spearphishing	Audio Capture	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
External Remote Services	Inter-Process Communication (x)	Boot or Logon Autostart Execution (x)	Boot or Logon Autostart Execution (x)	Boot or Logon Autostart Execution (x)	Exploitation for Credential Access	Browser Bookmark Discovery	Lateral Tool Transfer	Automated Collection	Data Encoding (x)	Exfiltration Over Alternative Protocol (x)	Data Encrypted for Impact
Hardware Additions	Native API	Boot or Logon Initialization Scripts (x)	Boot or Logon Initialization Scripts (x)	Boot or Logon Initialization Scripts (x)	Forced Authentication	Cloud Service Dashboard	Remote Service Session Hijacking (x)	Clipboard Data	Data Obfuscation (x)	Exfiltration Over C2 Channel	Data Manipulation (x)
Replication Through Removable Media	Scheduled Task/Job (x)	Browser Extensions	Create or Modify System Process (x)	Execution Guardrails	Input Capture (x)	Cloud Service Discovery	Remote Services (x)	Data from Cloud Storage Object	Dynamic Resolution (x)	Disk Wipe (x)	Defacement (x)
Supply Chain Compromise (x)	Shared Modules	Compromise Client Software Binary	Event Triggered Execution (x)	Exploitation for Defense Evasion	Man-in-the-Middle (x)	Domain Trust Discovery	Replication Through Removable Media	Data from Information Repositories (x)	Encrypted Channel (x)	Exfiltration Over Physical Medium (x)	Endpoint Denial of Service (x)
Trusted Relationship	Software Deployment Tools	Create Account (x)	Group Policy Modification	File and Directory Permissions Modification (x)	Modify Authentication Process (x)	Network Sniffing	Software Deployment Tools	Data from Local System	Fallback Channels	Firmware Corruption	Inhibit System Recovery
Valid Accounts (x)	User Execution (x)	Exploitation for Privilege Escalation	Group Policy Modification	Hide Artifacts (x)	OS Credential Dumping (x)	File and Directory Discovery	Taint Shared Content	Data from Network Shared Drive	Ingress Tool Transfer	Exfiltration Over Web Service (x)	Resource Hijacking
	Windows Management Instrumentation	Event Triggered Execution (x)	Hijack Execution Flow (x)	Hijack Execution Flow (x)	Steal or Forge Kerberos Tickets (x)	Network Service Scanning	Use Alternate Authentication Material (x)	Data from Removable Media	Multi-Stage Channels	Scheduled Transfer	Service Stop
		External Remote Services	Hijack Execution Flow (x)	Impair Defenses (x)	Steal or Forge Kerberos Tickets (x)	Network Share Discovery	Man in the Browser	Data Staged (x)	Non-Application Layer Protocol	Transfer Data to Cloud Account	System Shutdown/Reboot
		Hijack Execution Flow (x)	Process Injection (x)	Indicator Removal on Host (x)	Steal or Forge Kerberos Tickets (x)	Network Sniffing	Man-in-the-Middle (x)	Email Collection (x)	Protocol Tunneling		
		Scheduled Task/Job (x)	Process Injection (x)	Indirect Command Execution	Two-Factor Authentication Interception	Password Policy Discovery	Screen Capture	Input Capture (x)	Remote Access Software		
		Implant Container Image	Valid Accounts (x)	Masquerading (x)	Unsecured Credentials (x)	Peripheral Device Discovery	Video Capture	Proxy (x)	Traffic Signaling (x)		
		Office Application Startup (x)		Modify Authentication Process (x)		Permission Groups Discovery (x)			Web Service (x)		
		Pre-OS Boot (x)		Modify Registry							
		Scheduled Task/Job (x)		Obfuscated Files or Information (x)							
		Server Software Component (x)		Pre-OS Boot (x)							
		Traffic Signaling (x)		Process Injection (x)							
		Valid Accounts (x)		Revert Cloud Instance							
				Rogue Domain Controller							
				Rootkit							
				Signed Binary Proxy Execution (x)							
				Signed Script Proxy Execution (x)							
				Subvert Trust Controls (x)							
				Template Injection							
				Traffic Signaling (x)							
				Trusted Developer Utilities Proxy Execution (x)							
				Unused/Unsupported Cloud Regions							
				Use Alternate Authentication Material (x)							
				Valid Accounts (x)							
				Virtualization/Sandbox Evasion (x)							
				XSL Script Processing							

Figure 1. The ATT&CK for Enterprise Matrix

Furthermore, some techniques can be broken down into sub-techniques that describe in more detail how those behaviors can be performed. For example, Pre-OS Boot has three sub-techniques consisting of Bootkit, Component Firmware, and System Firmware to describe how persistence is achieved before an operating system boots. Figure 2 depicts the Persistence Tactic with techniques and four techniques expanded to show sub-techniques: Account Manipulation, Pre-OS Boot, Scheduled Task/Job, and Server Software Component

3.2 Technology Domains

ATT&CK is organized in a series of “technology domains” - the ecosystem an adversary operates within that provides a set of constraints the adversary must circumvent or take advantage of to accomplish a set of objectives. To date MITRE has defined three technology domains – Enterprise (representing traditional enterprise networks and cloud technologies), Mobile (for mobile communication devices), and ICS (for industrial control systems). Within each technology domain, ATT&CK defines multiple “platforms” - the system an adversary is operating within. A platform may be an operating system or application (e.g. Microsoft Windows). Techniques and sub-techniques can apply to multiple platforms. Table 1 lists the platforms currently defined for ATT&CK technology domains except for ICS, which will be documented in a separate philosophy paper.

The scope of ATT&CK also expands beyond technology domains with PRE-ATT&CK. PRE-ATT&CK covers documentation of adversarial behavior during requirements gathering, reconnaissance, and weaponization before access to a network is obtained. It is independent of technology and models an adversary’s behavior as they attempt to gain access to an organization or entity through the technology they leverage, spanning multiple domains.

Table 1. ATT&CK Technology Domains

Technology Domain	Platform(s) defined
Enterprise	Linux, macOS, Windows, AWS, Azure, GCP, SaaS, Office 365, Azure AD
Mobile	Android, iOS

3.3 Tactics

Tactics represent the “why” of an ATT&CK technique or sub-technique. It is the adversary’s tactical objective: the reason for performing an action. Tactics serve as useful contextual categories for individual techniques and cover standard notations for things adversaries do during an operation, such as persist, discover information, move laterally, execute files, and exfiltrate data. Tactics are treated as “tags” within ATT&CK where a technique or sub-technique is associated or tagged with one or more tactic categories depending on the different results that can be achieved by using a technique.

Each tactic contains a definition describing the category and serves as a guide for what techniques should be within the tactic. For example, Execution is defined as a tactic that represents (sub-)techniques that result in execution of adversary-controlled code on a local or remote system. This tactic is often used in conjunction with initial access as the means of executing code once access is obtained, and lateral movement to expand access to remote systems on a network.

Additional tactic categories may be defined as needed to more accurately describe adversary objectives. Applications of the ATT&CK modeling methodology for other domains may require new or different categories to associate techniques even though there may be some overlap with tactic definitions in existing models.

3.4 Techniques and Sub-Techniques

Techniques represent “how” an adversary achieves a tactical objective by performing an action. For example, an adversary may dump credentials from an operating system to gain access to useful credentials within a network. Techniques may also represent “what” an adversary gains by performing an action. This is a useful distinction for the Discovery tactic as the techniques highlight what type of information an adversary is after with a particular action.

Sub-techniques further break down behaviors described by techniques into more specific descriptions of how behavior is used to achieve an objective. For example, with OS Credential Dumping, there are several more specific behaviors under this technique that can be described as sub-techniques, including accessing LSASS Memory, the Security Account Manager, or accessing /etc/passwd and /etc/shadow.

There may be many ways, or techniques, to achieve tactical objectives, so there are multiple techniques in each tactic category. Likewise, there may be multiple ways to perform a technique so there can be multiple distinct sub-techniques under a technique.

3.4.1 Procedures

Procedures are another important component of the TTP concept, and we cannot talk about tactics and techniques without also including procedures as well. Within ATT&CK, procedures are the specific implementation adversaries have used for techniques or sub-techniques. For example, a procedure could APT28 using PowerShell to inject into lsass.exe to dump credentials by scraping LSASS memory on a victim.

The two important aspects to note about procedures in ATT&CK are that it is how an adversary uses techniques and sub-techniques and that a procedure can span multiple techniques and sub-techniques. Expanding on the prior example, the procedure the adversary uses to dump credentials includes PowerShell, Process Injection, and LSASS Memory, which are all distinct behaviors. Procedures may also include use of specific tools in how they’re performed.

Procedures are documented in ATT&CK as the observed in-the-wild use of techniques in the "Procedure Examples" section of the technique and sub-technique pages.

3.4.2 Technique and Sub-Technique Object Structure

These terms represent sections and important information included within each technique and sub-technique entry within the **Enterprise ATT&CK model**. Items are annotated by **tag** if the data point is an informational reference on the technique that can be used to filter and pivot on, and **field** if the item is a free text field used to describe technique-specific information and details. Items marked with **relationship** indicate fields that are associated to object entity relationships with groups, software, or mitigations. Table 2 lists all of the data items currently defined for techniques and sub-techniques in ATT&CK. Data items marked with * denote the element is required and additional information about specific requirements dependent on tactic category is in the description.

		for a given (sub-)technique and should be documented as such.
Mitigation*	Relationship / Field	Configurations, tools, or process that can prevent a (sub-)technique from working or having the desired outcome for an adversary. This section is intended to inform those responsible for mitigating against adversaries (such as network defenders or policymakers) to allow them to take an action such as changing a policy or deploying a tool. Mitigation fields are populated on a (sub-)technique page when a mitigation object is associated to a (sub-)technique.. The relationship describes the details of how a specific mitigation can be applied to the (sub-)technique. Mitigation recommendations remain vendor agnostic, recommending the general method or capability class rather than a specific tool. Mitigation may not always be possible for a given (sub-)technique and is documented as such if no relationships to a given (sub-)technique are present.

3.4.3 Sub-Technique Details

The addition of sub-techniques to ATT&CK in 2020 marked a significant shift to how behavior is described within the knowledge base. The change was driven by the need to fix some of the technique abstraction level issues that occurred as ATT&CK grew over the years. Some techniques were very broad and some were narrow, only describing a very specific behavior. The imbalance that this led to created unintended consequences that made it not only difficult to visualize ATT&CK, but also hard to understand the purpose behind some techniques because ATT&CK became so large.

Our goals for how sub-technique benefits ATT&CK were as follows:

- Make the abstraction level of techniques similar across the knowledge base
- Reduce the number of techniques to a manageable level
- Provide a structure to allow sub-techniques to be added easily that would decrease the need to make changes to techniques over time
- Demonstrate that techniques are not shallow and can have many ways they can be performed that should be considered
- Simplify the process for adding new technology domains to ATT&CK that use overlapping techniques
- Enable more detailed data sources and descriptions for how a behavior can be observed on specific platforms

There are several points to consider about how sub-techniques are used within ATT&CK.

Sub-techniques do not have a one-to-many relationship to techniques. Each sub-technique will only have a relationship to a single parent technique and no other to avoid complicated and difficult to maintain relationships across the model. There were cases where a sub-technique having multiple parents may have made sense with techniques that span multiple tactics. For example, only some sub-techniques of Scheduled Task/Job can be used for privilege escalation in addition to persistence. To address this case, sub-techniques are not required to fall under all tactics that a technique is in. As long as a sub-techniques conceptually falls under a technique (e.g. sub-techniques that are conceptually a type of process injection will be under process injection), each sub-technique can contribute to which tactics a technique is a part of but are not required to fulfill every parent technique's tactic (i.e. the Process Hollowing sub-technique can be used for Defense Evasion but not Privilege Escalation even though the Process Injection technique covers both tactics).

Not all techniques will have sub-techniques. Organizationally, this structural consistency makes sense. In practice, however, it was difficult to implement. Even though the purpose behind sub-techniques was to provide more detail on how techniques can be used, there remains several techniques that do not have a natural breakout into sub-techniques or do not make sense to generalize into higher level techniques. Two-Factor Authentication Interception is one example.

Sub-techniques are often but not always operating system or platform specific. Having platform specific sub-techniques makes focusing the content of that technique on a particular platform much easier, but we found that sub-techniques are not always malleable enough for this purpose. It would have resulted in several of the same sub-techniques each for different platforms, such as Local, Domain, and Default Valid Accounts for each of Windows, Mac, Linux, etc. This is especially the case with techniques that apply to network communications in the Command and Control tactic since network use is often operating system and platform agnostic.

Some information within a technique will be inherited by its child sub-techniques. Both mitigation and data source information will have an upwards inheritance to the technique from sub-techniques.

Groups and software procedure examples are not inherited between techniques and sub-techniques. When reviewing threat intel to determine which level to map an example to, if the information available is specific enough to assign it to a sub-technique then the information will become a procedure example only for the sub-technique. If the information is ambiguous such that a sub-technique cannot be identified, then the information will be mapped to the technique. The same procedure should not be mapped to both in order to reduce redundant relationships.

3.5 Groups

Known adversaries that are tracked by public and private organizations and reported on in threat intelligences reports are tracked within ATT&CK under the Group object. Groups are defined as named intrusion sets, threat groups, actor groups, or campaigns that typically represent targeted, persistent threat activity. ATT&CK primarily focuses on APT groups though it may also include other advanced groups such as financially motivated actors.

Groups can use techniques directly or employ software that implements techniques.

3.5.1 Group Object Structure

Items are annotated by **tag** if the data point is an informational reference on the group that can be used to filter and pivot on, and **field** if the item is a free text field used to describe group-specific information and details. Items marked with **relationship** indicate fields that are associated to object entity relationships with techniques or software that use the technique. Data items marked with * denote the element is required

Table 3. ATT&CK Group Model

Data Item	Type	Description
Name*	Field	The name of the adversary group.
ID*	Tag	Unique identifier for the group within the knowledge base. Format: G#####.
Associated Groups	Tag	Names that have overlapping reference to a group entry and may refer to the same or similar group in threat intelligence reporting.
Version*	Field	Version of the group in the format of MAJOR.MINOR.
Contributor	Tag	List of non-MITRE contributors (individual and/or organization) from first to most recent that contributed information on, about, or supporting the development of a group profile.
Description*	Field	A description of the group based on public threat reporting. It may contain dates of activity, suspected attribution details, targeted industries, and notable events that are attributed to the group's activities.
Associated Group Descriptions	Field	Section that can be used to describe the associated group names with references to the report used to tie the associated group to the primary group name.
Techniques / Sub-Techniques Used*	Relationship / Field	List of (sub-)techniques that are used by the group with a field to describe details on how the technique is used. This represents the group's procedure (in the context of TTPs) for using a technique. Each technique should include a reference.
Software	Relationship / Field	List of software that the group has been reported to use with a field to describe details on how the software is used.

3.6 Software

Adversaries commonly use different types of software during intrusions. Software can represent an instantiation of a technique or sub-technique, so they are also necessary to categorize within ATT&CK for examples on how techniques are used. Software is broken out into two high-level categories: tools and malware.

- **Tool** - Commercial, open-source, built-in, or publicly available software that could be used by a defender, pen tester, red teamer, or an adversary. This category includes both software that generally is not found on an enterprise system as well as software generally available as part of an operating system that is already present in an environment. Examples include PsExec, Metasploit, Mimikatz, as well as Windows utilities such as Net, netstat, Tasklist, etc.
- **Malware** - Commercial, custom closed source, or open source software intended to be used for malicious purposes by adversaries. Examples include PlugX, CHOPSTICK, etc.

The software categories could be broken down further, but the idea behind the current categorization was to show how adversaries use tools and legitimate software to perform actions much like they do with traditional malware.

3.6.1 Software Object Structure

Items are annotated by **tag** if the data point is an informational reference on the software that can be used to filter and pivot on, and **field** if the item is a free text field used to describe software-specific information and details. Items marked with **relationship** indicate fields that are associated to object entity relationships with techniques or groups. Data items marked with * denote the element is required.

Table 4. ATT&CK Software Model

Data Item	Type	Description
Name*	Field	The name of the software.
ID*	Tag	Unique identifier for the software within the knowledge base. Format: S#####.
Associated Software	Tag	Names that have overlapping reference to a software entry and may refer to the same or similar software in threat intelligence reporting.
Version*	Field	Version of the software in the format of MAJOR.MINOR.
Contributor	Tag	List of non-MITRE contributors (individual and/or organization) from first to most recent that contributed information on, about, or supporting the development of a software profile.
Type*	Tag	Type of software: malware or tool.
Platform*	Tag	Platform the software can be used on. E.g., Windows.
Description*	Field	A description of the software based on technical references or public threat reporting. It may contain ties to groups known to use the software or other technical details with appropriate references.
Associated Software Descriptions	Field	Section that can be used to describe the associated software names with references to the report used to

		tie the associated software to the primary software name.
Techniques / Sub-Techniques Used*	Relationship / Field	List of (sub-)techniques that are implemented by the software with a field to describe details on how the technique is implemented or used. Each technique should include a reference.
Groups	Relationship / Field	List of groups that the software has been reported to be used by with a field to describe details on how the software is used. This information is populated from the associated group entry.

3.7 Mitigations

Mitigations in ATT&CK represent security concepts and classes of technologies that can be used to prevent a technique or sub-technique from being successfully executed. There are 41 mitigations in ATT&CK for Enterprise as of March 2020 and include mitigations such as Application Isolation and Sandboxing, Data Backup, Execution Prevention, and Network Segmentation. [7] Mitigations are vendor product agnostic and only describe categories or classes of technologies, not specific solutions.

Mitigations are represented by objects similar to groups and software where relationships signify how a mitigation can mitigate a technique or sub-technique. ATT&CK for Mobile was the first knowledge base to use the object format for mitigations. ATT&CK for Enterprise was changed from a free text field to describe mitigation behavior to the object format in the July 2019 update. Both Enterprise and Mobile have their own sets of mitigation categories with minimal overlap between them.

3.7.1 Mitigation Object Structure

Items are annotated by **tag** if the data point is an informational reference on the mitigation that can be used to filter and pivot on, and **field** if the item is a free text field used to describe mitigation-specific information and details. Items marked with **relationship** indicate fields that are associated to object entity relationships with techniques or sub-techniques. Data items marked with * denote the element is required.

Table 5. ATT&CK Mitigation Model

Data Item	Type	Description
Name*	Field	The name of the mitigation category.
ID*	Tag	Unique identifier for the mitigation within the knowledge base. Format: M####.
Description*	Field	A description of the mitigation based.
Version*	Field	Version of the mitigation in the format of MAJOR.MINOR.

3.9 Versioning

ATT&CK uses a system for versioning objects (techniques, sub-techniques, groups, software, and mitigations), the matrix view of domains, and releases. The system is designed to inform users when parts of ATT&CK have changed, give an indication as to the degree of the change, allow users to differentiate between versions of the matrix, and have stable references for content releases.

Versions will only increment between content releases. That means that if two changes are made to a technique between scheduled updates, then the version will only increase once.

3.9.1 Objects

In ATT&CK, objects refer to any item in the knowledge base that can have a relationship with another object. Each has their own criteria for how versions are incremented between releases.

All objects are assigned a two part numerical version MAJOR.MINOR that starts at 1.0 for any new object.

3.9.1.1 Techniques and Sub-Techniques

Major version changes consist of name changes and scope changes which should happen infrequently. Scope changes are a modification of how the technique could be interpreted or what it covers or does not cover in the description and include changes to its assigned tactics.

Minor version changes consist of descriptive information change such as minor updates that do not change the scope, procedure examples, detections, mitigations, and references. They also include any metadata changes such as platforms, required permissions, data sources, defenses bypassed, etc.

3.9.1.2 Groups

Major version changes consist of changes or additions to associated groups as well as changes to the group's description, which should happen infrequently.

Minor version changes consist of changes to references and relationships to techniques and software.

3.9.1.3 Software

Major version changes consist of changes or additions to associated software as well as changes to the software's description, which should happen infrequently.

Minor version changes consist of changes to references and relationships to techniques and groups.

3.9.1.4 Mitigations

Major version changes consist of changes to the scope of what the mitigation covers and changes to the name of the mitigation, which should happen infrequently.

Minor version changes consist of changes to a mitigation's description that does not impact its scope as well as changes to references and relationships to techniques.

3.9.1.5 Deprecation

Objects may be deprecated when they are deemed no longer beneficial to track as part of the knowledge base. This could happen for several reasons, including combining technique ideas together or removing an unnecessary object.

Deprecated objects are not deleted from the knowledge base and are still maintained in the STIX repositories, but they no longer show up in the navigation bar and matrix within the main ATT&CK website.

3.9.2 Matrix

Each matrix that appears on the ATT&CK website is assigned a last modified timestamp that serves as its version number. This applies to Enterprise (and related platforms), Cloud (and related platforms), Mobile (and related platforms), and PRE-ATT&CK.

3.9.3 Releases

A release occurs when the changes to the STIX representation of ATT&CK are bundled and released to the GitHub CTI repository [9] along with any updates to the ATT&CK website. Prior versions of the content and website are saved and stored for historical reference. [10]

4 The ATT&CK Methodology

The previous sections of this document have described and defined the purpose and structure of the ATT&CK knowledge base. This section describes the conceptual components of the methodology used in the creation and maintenance of ATT&CK. It also describes the process recommended to determine if and when new techniques should be added to the knowledge base and how threat intelligence is used to form the group and software technique profiles.

The information within ATT&CK has evolved over time, as have the considerations used for what information gets included and how it's structured. The process is as much of an art as it is a science but remains focused on an accurate representation of how adversaries conduct operations in a way that's easy to categorize the actions they take and relate those actions to sensors, system configurations, and countermeasures that defenders can use to detect and/or stop those actions.

4.1 Conceptual

There are three conceptual ideas that are core to the philosophy behind ATT&CK:

- It maintains the adversary's perspective;
- It follows real-world use of activity through empirical use examples;
- The level of abstraction is appropriate to bridge offensive action with possible defensive countermeasures.

4.1.1 Adversary's Perspective

ATT&CK takes on the perspective of an adversary in its terminology and descriptions for tactics and techniques described in the model. By contrast, many security models describe desired

security from a defender's perspective with a top-down view, such as the CIA² model, focus on vulnerability scoring, such as CVSS [6], or primarily account for risk calculations, such as DREAD [7].

ATT&CK's use of an adversary's perspective makes it easier to understand actions and potential countermeasures in context than it would from a purely defense perspective. For detection, oftentimes defensive analysts are presented with alerts with little to no context about the event that caused the alert. This may cause a shallow frame of reference for what caused those alerts and how that cause relates to other events that may have occurred on a system or network.

The perspective shift changes the question from what *did* happen based on a list of available resources to what *could* happen with a framework for aligning a defensive strategy to the adversary's playbook. In part, ATT&CK provides a more accurate frame of reference for how to approach assessing defensive coverage. It conveys the relationships and dependencies between adversarial actions and information in a way that's agnostic of any particular defensive tool or method of collecting data. Defenders are then able to follow the adversary's motivation for individual actions and understand how the actions and dependencies relate to specific classes of defenses that may be deployed in an environment.

4.1.2 Empirical Use

The activity described by ATT&CK is largely drawn from publicly reported incidents on suspected advanced persistent threat group behavior, which provides a grounding for the knowledge base so that it accurately portrays activity happening or likely to happen in the wild. ATT&CK also draws from techniques discovered and reported through offensive research into areas that adversaries and red teams are likely to leverage against enterprise networks, such as techniques that can subvert modern and commonly used defenses. The tie to incidents keeps the model grounded to real-world threats that are likely to be encountered rather than theoretical techniques that are unlikely to be seen due to difficulty of use or low utility.

4.1.2.1 Sources of Information

New information relevant to ATT&CK techniques can come from many different sources. These sources are used to help meet the empirical use criteria:

- Threat intelligence reports
- Conference presentations
- Webinars
- Social media
- Blogs
- Open source code repositories
- Malware samples

² Confidentiality, Integrity, and Availability

4.1.2.2 Community Contributions

ATT&CK relies heavily upon input from the community into what they see happening in-the-wild in order to remain up to date with relevant information. [13] MITRE's role in the process is to collect, prioritize, and curate the information that is received to ensure it aligns with ATT&CK and benefits the community's understanding of adversary behavior and improves how the community can defend against those behaviors. The information may be used in different ways depending on where the information comes from and the vantage the contributing organization or individual has.

Threat intelligence analysts typically track incidents, threat groups, and how their TTPs evolve over time. CTI is the foundation on which ATT&CK is built and provides one of the best sources of information to inform new techniques as well as groups and software.

Defenders see adversaries in action and are often in a position to see when new techniques are being used. Defenders in this context refer to threat hunters, malware analysts, and incident responders. Observations by defenders are another great source of information for ATT&CK.

Red teamers may not track adversary groups or be in a position to see techniques in-the-wild, but they can provide a useful source of information on how techniques are done. Red teams also develop or use open source software that may also be used by adversaries in-the-wild.

Contributions to ATT&CK expand beyond just techniques. New and updated information related to detections, data sources, mitigations, best practices and other aspects of ATT&CK are used to enhance the information in the knowledge base.

4.1.2.3 Un(der)reported Incidents

The vast majority of incidents discovered are not reported publicly. Unreported, or underreported, incidents can contain valuable information on how adversaries behave and engage in operations. Often, the techniques used can be separated from potentially sensitive or damaging information and help provide insights into new techniques and variations, as well as statistical data to show prevalence of use.

This type of circumstantial evidence of use is valuable and is taken into consideration as empirical use related data when adding new information into ATT&CK based on community contributions.

4.1.3 Abstraction

The level of abstraction for adversary tactics and techniques within ATT&CK is an important distinction between it and other types of threat models. High level models such as the various adversary lifecycles, including the Lockheed Martin Cyber Kill Chain®, Microsoft STRIDE, etc., are useful at understanding high level processes and adversary goals. However, these models are not effective at conveying what individual actions adversaries make, how one action relates to another, how sequences of actions relate to tactical adversary objectives, and how the actions correlate with data sources, defenses, configurations, and other countermeasures used for the security of a platform and domain.

By contrast, exploit databases and models describe specific instances of exploitable software – which are often available for use with code examples – but are very far removed from the

circumstances in which they could or should be used as well as from the difficulty of using them. Similarly, malware databases also exist but typically lack context around how the malware is used and by whom. They also do not take into account how legitimate software can be used for malicious purposes.

A mid-level adversary model like ATT&CK is necessary to tie these various components together. The tactics and techniques in ATT&CK define adversarial behaviors within a lifecycle to a degree where they can be more effectively mapped to defenses. The high-level concepts like Control, Execute, and Maintain are further broken down into more descriptive categories where individual actions on a system can be defined and categorized. A mid-level model is also useful to put lower level concepts into context. Behavior-based techniques are the focus as opposed to exploits and malware because they are numerous but are difficult to reason about them with a holistic defensive program other than regular vulnerability scans, rapid patching, and IOCs. Exploits and malicious software are useful to an adversary toolkit, but to fully understand their utility, it's necessary to understand the context in which they can be used to achieve a goal. The mid-level model is also a useful construct to tie in threat intelligence and incident data to show who is doing what as well as the prevalence of use for particular techniques. Figure 4 shows a comparison of the level of abstraction between high, mid, and low level models and threat knowledge databases:

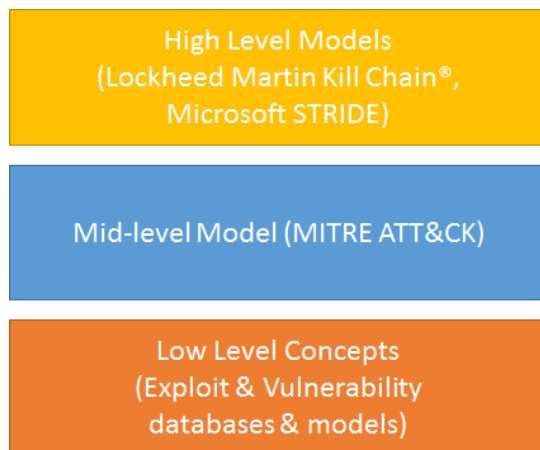


Figure 5. Abstraction Comparison of Models and Threat Knowledge Databases

What the ATT&CK technique abstraction provides:

- A common taxonomy of individual adversary actions and goals understood by both offense and defense.
- An appropriate level of categorization to relate adversary's action and *specific* ways of defending against it.

4.2 Tactics

Since tactics represent the tactical goals of an adversary, these remain relatively static over time because adversary goals are unlikely to change. Tactics combine aspects of what the adversary is trying to accomplish with what platform and domain they are operating within. Often these goals will be similar across platforms, which is why the Enterprise ATT&CK tactics are consistent across Windows, macOS, and Linux, and are even very similar to the Use Device Access tactics in ATT&CK for Mobile. Places where they differ are going to be where adversary goals and platform or domain technologies differ. An example of this is again evident with the ATT&CK for Mobile to cover how adversaries may downgrade or intercept connections between mobile devices and their network or service provider.

There may be cases where tactics need to be refined for better definition of the actions occurring. In the original ATT&CK for Enterprise, Windows the Collection tactic did not exist; instead it was included as part of Exfiltration. This representation fit sufficiently at the time because it was largely seen as one action—an adversary exfiltrates information but did not accurately represent the distinct motives and actions necessary for successful exfiltration. Where the data comes from and how it is obtained is equally as important as how an adversary removes the data from an environment and also represents distinct places where those actions can be detected. There is also a timing difference between when an adversary may collect information and when they exfiltrate it. Thus, a determination was made to break that tactic into two and describe Collection separately.

New tactics will follow the need to define existing, but uncategorized, or new adversary goals as a way to provide accurate context for what an adversary is accomplishing by performing a technique action.

4.2.1 Impact

The types of tactics in ATT&CK have historically aligned to covering adversaries primarily focused on breaching the confidentiality of information. Goals such as initial access, discovery, and credential access are commonly used to gain and expand access within an environment with an ultimate objective of stealing information through collection and exfiltration. However, these tactics did not cover disruptive and/or destructive attacks against information or systems. In 2019, the Impact tactic was added to ATT&CK to address that lack of coverage. With the rise of targeted ransomware, disk wiper incidents, manipulation of financial transactions, and large scale distributed denial of service attacks, it was important for ATT&CK to maintain parity with the behavior that adversaries are using even if their goals are not focused on exfiltration of data.

Rather than include all possible types of behaviors not covered elsewhere in ATT&CK, techniques in the Impact tactic specifically involve only attacks impacting the integrity or availability of information or systems. Along with the other tactics in ATT&CK, this increases the scope of ATT&CK to cover the traditional Confidentiality, Integrity, and Availability, or CIA triad. Attacks on availability reduce or remove the ability to use a system or the information on it by damaging it or otherwise reducing its utility. For example, overwriting the master boot record (MBR) of a computer, activity which falls under Disk Structure Wipe, renders the system unable to boot and unavailable to users. Attacks on integrity manipulate the accuracy or completeness of information. For example, an attacker modifying the balance of a bank account

stored in a data base, activity which falls under Data Manipulation: Stored Data Manipulation, damages the integrity of the balance information. Each technique and sub-technique in the Impact tactic includes a mandatory “Impact Type” tag with a value of “Availability” or “Integrity” indicating which one the (sub-)technique impacts.

Similar to other tactics in ATT&CK, it’s important to take into account adversary goals when leveraging Impact techniques. An adversary deleting files in order to decrease their likelihood of detection on an end system would fall under Indicator Removal on Host: File Deletion in Defense Evasion, rather than Data Destruction in Impact despite both techniques involving the deletion of files.

4.3 Techniques and Sub-Techniques

Techniques and sub-techniques are the foundation of ATT&CK and represent the individual actions adversaries make or pieces of information the adversary learns by performing an action.

4.3.1 What Makes a Technique or Sub-Technique

There are several factors to techniques and sub-techniques within ATT&CK. All factors are weighed in the decision process to create a technique or sub-technique and contribute to the information that populates their respective details within the knowledge base.

4.3.1.1 Naming

Technique names focus on the aspect of the technique that makes it unique—what the adversary achieves at an intermediate level of abstraction from using the tactic. Sub-techniques often signify how a technique is used at a lower level of abstraction. One example of the former is Credential Dumping [10] for Credential Access where dumping credentials is one method of gaining access to new credentials—and credentials can be dumped in several different ways. A sub-technique example of the latter is Rundll32 [11] for Defense Evasion. It sits at a lower level of abstraction where Rundll32 represents a specific way the technique Signed Binary Proxy Execution can be used. Industry-accepted terminology tends to be used if it is already established and documented through conference presentations, blog posts, other articles, etc.

4.3.1.2 Types of Technique Abstraction

Techniques generally fall into two levels of abstraction:

1. General techniques that apply to multiple platforms in general ways (e.g. Exploit Public-Facing Application [12] which depends on vulnerable software)
2. General techniques that apply to multiple platforms in specific ways (e.g. Process Injection [13] which has several platform specific ways it can be done)

Sub-techniques generally fall into one level of abstraction:

1. Specific ways a technique can be performed that may apply to one or more platforms (e.g. Rundll32 [11] as a specific way to perform Signed Binary Proxy Execution [14])

For the first, breaking out how that technique applies to multiple platforms with specific sections for each platform in the technical description likely does not make sense because the technique

describes a general platform agnostic behavior, such as much of the Command and Control tactic. The description is kept general and details are provided with references to the examples from the different platforms as needed.

Techniques that can be performed a few different ways to achieve the same or similar results are grouped under a general category of techniques, such as Credential Dumping. These techniques can apply to multiple platforms in specific ways. Those different ways would then be defined as sub-techniques that describe how those behaviors can apply individually based on platform.

Sub-techniques generally are specific ways an adversary acts against either against a particular platform or by using a similar concept that works similarly across platforms. Rundll32 is one example of the former that only applies to Windows systems. These sub-techniques tend to describe how individual components of the platform are abused by adversaries. Hidden Files and Directories is one example of the latter since it takes advantage of a similar concept that spans Windows, Linux, and Mac but is a specific example of how an adversary would hide artifacts on a system that is designated by the technique Hide Artifacts.

Sometimes techniques or sub-techniques can have multiple required steps within them, some of these steps may be relatable to other existing techniques or steps that could be individual techniques. When this occurs, it is important to focus on the distinguishing attribute of the behavior or what makes it different than the others.

4.3.1.3 Technical References

Technical references are provided to point users to further research or more detail on techniques. Areas where technical references are useful include: background on the technique, expected use in benign cases, general use examples, variations of a technique, relevant tools and open source code repositories, detection examples and best practices, and mitigation categories and best practices.

4.3.1.4 Adversary Use

ATT&CK also includes information on if (and by whom) a technique or sub-technique is used in the wild and its reported impacts. As mentioned in the empirical use section, there are many sources of this information. ATT&CK remains strongly tied to threat intelligence sources on persistent threat groups. As the scope of ATT&CK has expanded and been refined, so too have the criteria necessary to add information. ATT&CK also includes public offensive research used by red teams against enterprise networks since adversaries have been known to adopt such published techniques. There are also fewer persistent threat incidents reported against Linux and Mac systems than there are against Windows, causing available threat data to be substantially less available. General in-the-wild sources of data that are not necessarily tied to persistent threat group use may be used in lieu when the techniques align well with how persistent threats typically behave.

There are several general categories of empirical use information that can be used:

- **Reported** – Behavior is reported with in the wild use through public sources.
- **Reported, non-public** – Behavior use is reported in non-public sources but knowledge of the technique or sub-technique existing is present in public sources.

- **Underreported** – Behaviors that are likely being used but are not being reported for some reason. There may also be cases where circumstantial information that a technique is in use exists but it's generally difficult for information to be collected or disseminated stating the technique is in use due to sensitivities related to the source of information or method of collection. Discretion is used based on the credibility of the source.
- **Unreported** – There is no public or non-public source of intel saying a behavior is in use. This category may contain new offensive research used by red teams that has been published, but in the wild use by adversary groups is unknown. Discretion is used based on the utility of the technique or sub-technique and likelihood of use by adversaries.

4.3.1.5 Technique Distinction

Several factors are considered when including new information to determine where and how it fits into the model:

- **Objective-** What the technique or sub-technique is accomplishing. Similar techniques may be performed the same way to accomplish different tactics. Likewise, different techniques may accomplish the same tactic in different ways.
- **Actions-** How a technique or sub-technique is performed. Is the "trigger" different between techniques that distinguishes them even though the result may be the same or similar?
- **Use-** Who is using it? Are there multiple groups? If so, how is the use different or the same?
- **Requirements-** The components that are needed to use a technique or sub-technique, or are affected by use of a technique. For example, files, locations, registry changes, API calls, permissions, etc. What is the overlap of components between the techniques? Are they distinct or similar?
- **Detection-** What needs to be instrumented to detect use of the technique or sub-technique? This is related to requirements and actions but could differ across techniques that are related.
- **Mitigations-** What mitigation options available for the technique? Are they similar to or different from other techniques that are either performed in the same way or have the same result?

4.3.2 Creating New Techniques

When a potential new behavior is identified, there are several possible approaches to including it in ATT&CK:

- Adding an entirely new technique,
- Adding a new sub-technique under an existing technique, or
- Enhancing or abstracting an existing technique or sub-technique to make it inclusive of the newly-identified or otherwise previously uncategorized behavior.

This choice is not always clear – the following questions help guide the decision:

- What tactic does the behavior fall under? Do multiple tactics apply?
 - Within a tactic, are other techniques similar to this one?
 - If so, how are they similar?
 - Is the similarity enough to categorize them together?
 - Is it a specific way to perform an existing technique?
 - Does the empirical use reference support the tactic use?
 - Is it plausible that the behavior can be used for that tactic objective even if data is unavailable due to related techniques?
- For behaviors similar to existing techniques or sub-techniques:
 - Does the new behavior naturally fit under the similar technique as a new sub-technique?
 - How is the new behavior performed? Is it similar in execution to other techniques? How many different ways can it be performed with existing adversary malware and other tools?
 - Would a red or adversary emulation team conceptually group this technique with others or treat it separately?
 - Does the new behavior have a different detection method or set of methods than the existing technique?
 - Are there similar data sources or methods for creating analytics that are similar or different than existing techniques?
 - Does the new behavior have a different mitigation method or set of methods than the existing technique?
 - Is the implementation or deployment methods of the mitigation fundamentally different than existing techniques that can be inhibited by a similar mitigation?
 - Would creating a new technique be useful for an end user of the model?
 - Would defenders conceptually group this technique with others or treat it separately?

4.3.3 Enhancing Existing Techniques

If a new behavior is not conceptually different in how it is implemented or defended against, then it likely should be included in an existing technique or sub-technique. Further questions to consider when adding new information to an existing technique:

- What distinguishes this variation from existing methods of using the technique or sub-technique?
 - How is it performed?

- What analytic differences, if any, may be necessary to effectively detect use of or system and network side artifacts resulting from the technique being used?
- Are there different considerations for mitigation?

4.3.4 Named Adversary Groups Using Techniques

It is also important to consider adversary group usage of and variations to techniques and sub-technique to determine how they should be properly documented. These factors may also contribute to whether or not a new technique is created or an existing one enhanced.

- Are there different adversary groups that use this technique or sub-technique?
 - If so, how is it different?
 - Are the differences distinguishing characteristics of that group?
 - Should the differences be documented in the adversary group's profile for how they have been known to implement the technique?

4.3.5 Incorporation Threat Intelligence on Groups and Software within ATT&CK

Information about groups is derived from open source reporting, and each of the techniques and sub-techniques used should have a reference to the source that explains how the group uses it. ATT&CK is based upon open source references to ensure the traceability of information and allow users to evaluate information sources.

Sources should be known to be reputable within the cybersecurity community and demonstrate intelligence analysis best practices. Common sources include security vendor blogs, but other sources such as personal blogs or Twitter may be used provided the information is deemed to be reliable. Original sources should be used whenever possible as opposed to secondary reporting about sources. We do not accept leaked or classified information from any corporation or government as the basis for threat intelligence within ATT&CK.

Examples from publicly-available threat reporting sources are deemed to be reliable based on widely accepted criteria for evaluating information, including:

1. Is the source internally and externally consistent?
2. Is the source known to have reported reliably in the past?
3. Is the source widely used, respected, and referenced by cybersecurity analysts in the community?
4. Does the source contain spelling or grammatical errors?
5. Does the source demonstrate sound analysis methodology (including stating supporting evidence, confidence levels, and gaps)? Does it include analytic "leaps"?
6. Do other sources corroborate information provided?

When documenting techniques and sub-techniques used, multiple techniques may simultaneously apply to the same behavior. For example, HTTP-based Command and Control traffic over port 8088 would fall under both the Non-Standard Port technique and the Web Protocols sub-technique of Application Layer Protocol. This is to capture the various technical

aspects of a technique and relate them to specific reasons they are used and what data sources and countermeasures can be used by defenders. Analysts should also use caution and not assume a technique was used if it is not explicitly stated or could not have happened in any other way during the reported incident. In the same example, if Command and Control traffic is over HTTP, unless explicitly stated or known, an analyst should not assume the traffic is over port 80 because adversaries may use non-standard ports, as in the example.

Some groups in ATT&CK have multiple names associated with related sets of activity due to various organizations tracking the same (or similar) set(s) of activities by different names. Organizations' group definitions may be only partially overlapping and may disagree on specific activity. There could be several nuances that lead an analyst and organization to categorize adversary activity separately, such as differences in visibility into a group's suspected activity. [12] Despite this challenge, tracking associated groups for similar activity is useful to many users of ATT&CK, so the group pages make a best effort to track related naming based on public reporting. Similar to how techniques used must be cited, each associated group also must be cited. There could be additional information, or analysis based on incomplete or unavailable data, that may lead to changes in how adversary groups are categorized.

Techniques used by a group should focus on those techniques and sub-techniques believed to have been directly performed by adversaries, not those performed without adversary interaction by a specific software sample. Techniques performed by software should be listed under the appropriate software page, and that software then linked back to the group having used it using the relationship/field noted above.

4.3.5.1 Ungrouped Use of Techniques

Reports often include adversarial behavior and technique use for ungrouped or unnamed activity. This is still a very useful source of information. Just because activity is not correlated to a named group does not mean it should not be included as justification for a technique or enhancing information. Typically, this information is included as a reference within the technical section of a technique describing instances of how the technique may be used.

4.3.6 Examples of Applying the Methodology for New Techniques

This section considers two separate techniques – Process Injection and SQL Injection – and steps through the methodology described above to illustrate when and how to add new techniques to the ATT&CK knowledge base.

Process Injection – Analysis of a technique that exists within ATT&CK by applying the above methodology. Process Injection, sometimes referred to as DLL injection, is a class of behavior that describes how an adversary can use an existing benign, running process as a way to hide the presence of their code executing.

Considerations:

- This technique is used to hide from some common defenses, like process tree analysis. It also could be used to execute within a certain context of another process that has certain user rights or permissions.

- It applies to Windows and Linux systems and represents benign functionality used by legitimate software that can be used by adversaries for malicious purposes.
- It requires real-time telemetry from the system on running processes and interactions with processes through the API to effectively detect effective use. Some forensic detection of process injection is possible, depending on the variation used, from loaded libraries and other data sources but requires proper timing.
- Mitigation is difficult due to its benign usefulness in software. Some security features may mitigate aspects of this technique, such as application whitelisting that includes analysis of loaded modules, or code integrity that prevents processes from a lower integrity level from interfacing with processes running in at a higher integrity level.
- Many adversary groups use this technique, which is a component of tools, scripts, and malware.
- There are several variations of process injection, but most follow a common sequence of an initial adversary controlled process requesting access to a non-malicious process, loading code within it, and forcing that process to execute the new code.
- Some variations load DLLs from disk, while others perform reflective loading that do not require a file on disk.
- Related methods of execution require a binary to be put on disk and/or some configuration change that will load and execute the code in a new process representing different opportunities to detect and mitigate.
- Other related methods use different functionality provided by Windows to load and execute code, such as application shims.
- Similar concepts exist in Linux based systems for dynamically loading libraries into processes.

Conclusions:

- The core feature of this technique is loading malicious code within an existing live process.
- The technique is used widely across many groups of adversaries.
- There are several variations of this technique and the core behavior is distinct enough from other related methods of defense evasion and privilege escalation to warrant an individual entry.
- There are several variations within this core concept to include in the process injection entry which should be defined as sub-techniques under a process injection parent technique.
- Process injection should be included as a technique under defense evasion and privilege escalation. [13]

SQL Injection (SQLi) – an example analysis of a technique that is not explicitly in ATT&CK by applying the above methodology.

SQLi is a method of injecting code through an improperly secured web interface that is interpreted and executed by a database process. The resulting code execution can be used for a number of purposes, including adding or modifying information, gaining access to a system, causing the server to download and execute other code which may result in persistence, credential access, privilege escalation, collection, and exfiltration.

Considerations:

- SQLi may be performed to gain access to an externally facing web server in a DMZ or improperly positioned web server that would result in network compromise. It may also be performed to achieve lateral movement within an enterprise, but in-the-wild reported incidents have been scarce on this use case.
- Fundamentally, SQLi is exploiting a vulnerability in web application software due to poor code design and is not a benign behavior that an adversary could use for some purpose.
- SQLi is a predominant vulnerability that occurs frequently across many different types of web applications, regardless of language or platform they are written in.
- Software has been developed to automate SQLi; it is unlikely that this would be performed manually.
- For the external variation, data sources collecting traffic on the boundary would likely see this behavior. Application logs from the web and database server may be used as well. True positive detection may be difficult due to certain variance that can be used in frequency and timing of attempts and methods to hide indicators.
- For the internal variation, tools that may not normally be present within an enterprise network would likely need to be downloaded and used by an adversary. Depending on the tool and how it is used, it may create an enormous amount of traffic against an internally accessible web server. Internal netflow, packet capture, web logs, and endpoint monitoring may be used to detect aspects of the download and usage of the tool.
- There are many methods on how SQLi may reach a database through various malformed data inputs and parameters. How they are detected or mitigated are not fundamentally different from each other. Database input or web logs can be used to look for common SQLi inputs that result in code execution. Likewise, using secure web development and existing secure programming constructs mitigates a large number of SQLi instances.
- Adversaries have been known to use SQLi as a means of gaining access to externally available web servers. There is not good data available on use within internal networks for other purposes.

Conclusions:

- The context in which SQLi fits within an adversary's tactical goals puts it within attempts to gain access to a system through an existing software vulnerability. An example is for initial access in a network compromise by compromising an externally facing application.
- SQLi is a variation of an exploitation technique against a specific software technology and is an appropriate abstraction within how an adversary performs initial compromise. It

would not need to be described in various ways at this technique level due to the limited variations in how it is performed by an adversary, detected by defenders, or mitigated through proper software design. Additional resources can be cited as needed, such as CAPEC, CWE, OWASP that detail specifics.

- Include SQLi in ATT&CK as a technical detail enhancement of Exploit Public-Facing Application for gaining access to exposed web servers or databases. [15]

4.4 Applying the ATT&CK Methodology

ATT&CK succinctly organizes adversary tactics and techniques along with providing a common language used across security disciplines. These attributes make it a useful concept for those who need to defend against adversaries by better understanding their behavior. Even though ATT&CK focuses on how adversaries compromise and operate within computer information networks and related technologies, the methodology behind how it was built can be applied to other areas.

Since ATT&CK was published, MITRE has expanded it into several additional technology domains including mobile, cloud, and ICS. Still more domains could be researched, but given our criteria of basing the information in ATT&CK on in-the-wild use of techniques, oftentimes an application of the ATT&CK methodology does not mean that the result is an ATT&CK model. There are two cases where this could apply. The first case is where there exists little to no available threat intelligence on adversaries operating, either because there is no data collected and reported or there are no adversaries operating in that space. Building automation control systems could be one example. In this case, the process of identifying the model's structure and content may include significant amounts of theoretical or red team-derived behaviors. The second is when the model does not relate to adversary use of computer information technology networks, deviating from the core space that ATT&CK is designed to address. In this case, the model may be built around a completely different adversarial domain, such as misinformation, using the same criteria that ATT&CK was built upon with available in-the-wild use of techniques. The AMITT project by the Credibility Coalition is one such example where the ATT&CK methodology was applied to build a model describing misinformation and influence campaigns. [16] Both cases are a valid and potentially useful application of the methodology MITRE used to create and maintain ATT&CK even though they are not MITRE ATT&CK models.